

APPENDIX G: INFORMATION SECURITY

This appendix contains select Information Security Requirements, the Overarching Information Security Policy adopted by the Government of Saskatchewan (GoS), and the objectives and control statements contained within the comprehensive GoS Information Security Policies, Standards, and Specifications.

The Service Provider must ensure that its security Policies, Standards, and Controls for any Services delivered as part of the engagement align with those of the Government of Saskatchewan. Security Policies, Standards, and Controls must align with ISO27002:2013 framework for information security controls or an equivalent industry standard framework such as NIST with ISO mapping.

Further, the Service Provider is expected to create and maintain, throughout the lifetime of the engagement, a Customer Security Document (CSD) for the Ministry's required Services to ensure that all security requirements to protect its data and services are met. The CSD should be referenced in the Service Provider's Statement of Work and must be delivered early in the resulting engagement.

Table of Contents

APPENDIX G: INFORMATION SECURITY.....	1
Table of Contents.....	1
1. INFORMATION SECURITY REQUIREMENTS	2
1.1 General Information Security Requirements	2
1.2 Data Classification Security Requirements	3
2. OVERARCHING INFORMATION SECURITY POLICY	5
2.1 Purpose	5
2.2 Policy Scope.....	5
2.3 Foundational Security Principles.....	5
2.4 Minimum Security Requirements	6
2.5 Security Program Capability Objectives	7
2.6 Compliance and Disciplinary Action.....	9
2.7 Exceptions	9
3. GOVERNMENT OF SASKATCHEWAN INFORMATION SECURITY POLICIES.....	10
3.1 Information Security Policies	10

1. INFORMATION SECURITY REQUIREMENTS

Information security requirements specified in this section are based on the information security policies, standards, and specifications maintained by the Cyber Security and Risk Management Branch, Information Technology Division of the Ministry of SaskBuilds and Procurement. These requirements have been reviewed and accepted by the client ministry.

The purpose of the GoS information security policies is to provide a framework to manage information security for all GoS information systems. The GoS information security policies apply to all GoS employees, contractors, vendors, or agents granted access to GoS information assets.

All service providers who deliver or intend to deliver Solution and/or Services to the Government of Saskatchewan are expected to do so under established information security policies and, to the extent applicable and feasible, in alignment with the information security requirements specified below.

NOTE: Respondents who are short-listed in this competition may be asked to respond to a Vendor/Third-Party Risk Assessment Questionnaire. The questionnaire is intended to clarify service providers' information security posture and maturity.

1.1 General Information Security Requirements

All information security policies, standards, specifications, and communications procedures, as applicable to the resulting Solution or Services delivery engagement, shall be documented by the Successful Service Provider. This can be done within the Project Statement of Work (SOW) or referenced and appended to the SOW or other contractual documents. All such policies, standards, and specifications should be no less rigorous than those established by the GoS.

Additionally, the GoS requires the Service Provider to consider the following general information security requirements:

- The Service Provider should provide a single point of contact for security-related events. Under circumstances where the single point of contact is an individual, the Service Provider should also provide an escalation point;
- The Service Provider should deliver its proposed Solution and/or Services in accordance with established and documented information security policies, standards, and specifications;
- The Service Provider should deliver its proposed Solution and/or Services in accordance with any security-related service level metrics contained within a mutually agreed-upon Service Level Agreement, if applicable. In cases where service level metrics are not provided by the GOS, the Service Provider should propose such service levels as part of its service delivery. Such metrics could include, though may

not be limited to, frequency and detail of reporting, frequency of vulnerability scans, frequency and execution of patching, and other service level metrics and key performance indicators applicable;

- The Service Provider should accept that the GoS reserves the right to conduct periodic information security audits and assessments of the service provider(s) and its Solution or Services. Such audits may include, though are not necessarily limited to, Threat Risk Assessments (TRA), Privacy Impact Assessments (PIA), penetration testing, vulnerability scans and assessments, and audits of security controls for Solution and/or Services delivered;
- The Service Provider should accept that the results of any audits or assessments will be delivered to the client ministry and any issues identified which represent risk that the client ministry is unwilling to accept shall be addressed by the Service Provider to the satisfaction of the client ministry.

1.2 Data Classification Security Requirements

Information Assets are classified according to the following Information Classification levels to ensure that the cost of safeguards and level of protection are proportionate to the value of the asset:

- Class A: Could reasonably be expected to cause extremely serious personal or enterprise injury including significant financial loss, loss of life or public safety, social hardship, or major political or economic impact.
- Class B: Could reasonably be expected to cause serious personal or enterprise injury, loss of competitive advantage, loss of confidence in the government program, financial loss, legal action, or damage to partnerships, relationships, and reputation.
- Class C: Could reasonably be expected to cause significant injury to individuals or enterprises with limited financial loss, impact in services/performance levels, and reputation.
- Public: Will not result in injury to individuals, government, or private sector institutions.

GOS Information Assets for this system contain highly sensitive data and have been classified by the Information Owner as Class A. Additional information pertaining to this Information Classification is contained in Section 2 of this appendix.

As a result of the Information Classification and to the extent each is applicable, the Ministry requires the Service Provider's proposed Solution and Services meet each of the following data classification security requirements as a minimum baseline:

- The proposed Solution must ensure that all data at-rest, including data backups, always remain in Canada;

- The proposed Solution must ensure that all data in-transit, to the extent possible and feasible, including data backups, always remain in Canada;
- The proposed Solution must ensure that all data at-rest and in-transit, including data backups, is always encrypted end-to-end;
- The proposed Solution must accommodate authentication information passing in a secure manner between endpoint(s) and authentication source(s);
- The proposed Solution must support multi-factor authentication (“MFA”) for access to the data and for any support/administration of the Solution;
- The proposed Solution must support electronic credentials intended to achieve a very high credential strength and use a cryptographic token that:
 - uses a key and cryptographic mechanism validated at FIPS 140-2 Level 1 at a minimum;
 - requires either the use of:
 - a password or biometric by the individual to activate the cryptographic mechanism; or,
 - a password in combination with the cryptographic mechanism in the same authentication protocol; and,
 - follows the GoS Password Standard specified in the GoS Information Security Policy.
- The proposed Solution must have the ability to encrypt data for transfers between application and database servers;
- The proposed Solution must accommodate separation of GoS data from the data of other customers.

2. OVERARCHING INFORMATION SECURITY POLICY

All Service Providers who are granted access to GoS information are expected to deliver their Solution and/or Services in accordance with established information security policies, standards, and controls that are no less rigorous than those established by GoS.

2.1 Purpose

The purpose of this policy is to provide direction and a common standard for Government of Saskatchewan (GoS) entities in building appropriately robust cybersecurity capabilities to prevent, detect, and respond to information security threats.

Given the seriousness of cyber threats posed to governments and connected entities, a certain minimum standard of security capability must be met, while also providing for each entity to meet that standard according to their unique risks and means.

Policies that go beyond the minimum requirements are encouraged.

Additional information about the implementation of these capabilities can be found in the GOS security standards and other policy instruments

2.2 Policy Scope

In accordance with the 'One Government' approach, this policy applies to all Government of Saskatchewan employees, contractors, vendors, or any other agents granted access to the Organization's Information Assets.

This policy applies to all Government of Saskatchewan information systems including but not limited to all Operational Technology (OT) systems, IoT devices, computers, mobile devices, networking equipment, software, and data.

2.3 Foundational Security Principles

Principles provide an anchor for building security programs and are intended to guide security decisions. A successful implementation of information security embodies the following principles:

- Security is everyone's responsibility.
- Central coordination of IT security allows for the proper development of enterprise solutions and monitoring.
- Information Security will be practiced through a unified enterprise approach across government, which will create efficiencies and decrease costs through the creation of economies of scale and scope.
- Using modern, fit-for-use security and information protection technologies for the enterprise.
- Information Security processes and procedures will be readily adaptable to react to technology changes and unexpected events.
- Security follows the principles of 'least privilege' and 'separation of duties' with regard to performing security functions.

- Access to and transmission of data or resources should be secured, audited, and monitored at a level consistent with its sensitivity as reflected by its data classification.
- Any individual or service accessing sensitive data or resources, as defined by security policy and data classification, as well as legislative, regulatory, and contractual requirements, should be positively identified.
- The implementation of security controls is founded upon a solid understanding of information security requirements, threat and risk assessment, and risk management.
- Security will reduce the implementation time for projects by utilizing a common set of authentication, authorization, and encryption technologies and methodologies for new projects (application and infrastructure).
- Information security policy, objectives, and activities reflect and enable business objectives.

2.4 Minimum Security Requirements

In addition to fulfilling the broad security program objectives above, a minimum-security program rigor must be established. Information Asset owners must ensure that:

- A Security Awareness and Training program is implemented.
- Threat and Risk Assessments (TRA) are performed any time there is a new initiative/project, or any time there is a Significant Change in the Organization's environment.
- A risk register is maintained and reviewed annually to ensure that the Organization's security posture is always maintained at an acceptable level.
- Information Assets which store, process, or transmit the Organization's information are protected against unauthorized access, modification, and loss in accordance with its information classification level.
- Information Assets are monitored at a level consistent with their sensitivity as reflected by the information classification level.
- Security patches and software versions are kept up to date on all of the Organization's Information Assets that process, store, or transmit the Organization's information.
- All Payment Card Industry Data Security Standard (PCI-DSS) related activities are conducted by a PCI compliant vendor.
- A security incident response and threat detection program must be implemented.
- Security responsibilities for organizations must be assigned to roles.

All users of the Organization's systems must:

- Comply with the Organization's Information Security policies and security standards.
- Protect the Organization's Information Assets in a manner consistent with the information classification level.
- Access sensitive Information Assets only if there is a legitimate business need.
- Report Information Security Incidents immediately to the Organization's IT Service Desk.

2.5 Security Program Capability Objectives

In order to realize our mission statement, organizations must maintain a security program with appropriately robust capabilities across all domains, which apply the Foundational Security Principles and fulfil the following objectives:

If you want to go into more detail, Government's Cyber Security Branch have resources and artifacts that you may take advantage of. Please contact CSITInformationSecurityBranch@gov.sk.ca

Governance

Domain	Objective
Information Security Program	To define a target state for information security and governance structure that reflects the expectations and requirements of key stakeholders.
Organizational Structure	To manage information security within the organization. Security activities shall be co-ordinated by representatives from different parts of the organization with relevant roles and job functions
Security Culture and Awareness	To establish a security awareness and training program and develop and communicate acceptable use policies.
Security Risk Management	To develop a security risk management program that integrates with enterprise-level risk management programs or practices.
Security Policies	To provide management direction and support for information security in accordance with business requirements and relevant laws and regulations.
Security Compliance Management	To avoid breaches of any law, statutory, regulatory or contractual obligations, and of any security requirements.
Security Audit	To ensure compliance of systems with organizational security policies and standards and maximize the effectiveness of and minimize interference to/from the information systems audit process.

Operations

Domain	Objective
Identity and Access Management	To prevent unauthorized access to operating systems by assigning a unique identifier (user ID) for all users and choosing a suitable authentication technique to substantiate the claimed identity of a user.
Information Asset Management	To achieve and maintain appropriate protection of organizational assets.

Data Security & Privacy	To ensure data protection and privacy as required in relevant legislation, regulations, and, if applicable, contractual clauses.
Network Security	To ensure the protection of information in networks and the protection of the supporting infrastructure.
Endpoint Security	To protect endpoint sessions by limiting unsuccessful login attempts and locking out sessions after predetermined periods of inactivity.
Malicious Code Protection	To implement malware protection on endpoints and appropriate gateways and to prevent errors, loss, unauthorized modification or misuse of information in applications.
Application Security Lifecycle	To Ensure applications are developed, deployed, and maintained in secure manner by using practices such as DevSecOps
Vulnerability Management	To reduce risks resulting from exploitation of published technical vulnerabilities.
Cryptography Management	To protect the confidentiality, authenticity or integrity of information by cryptographic means.
Physical Security	To prevent unauthorized physical access, damage and interference to the organization's premises and information.
Human Resource Security	To ensure that employees, contractors and third-party users understand their responsibilities, and are suitable for the roles they are considered for, and to reduce the risk of theft, fraud or misuse of facilities.
Configuration and Change Management	To control changes to information by reviewing and approving prior to implementation.
Vendor Risk Management	To implement and maintain the appropriate level of information security and service delivery in line with third party service delivery agreements.
Cloud Security	To protect data in the cloud based on the data classification level across environments.
Security Threat Detection	To implement a process by which you find threats on your network, your systems or your applications and to detect threats before they are exploited as attacks.
Log and Event Management	To provide the capability to detect events, make sense of them and determine the appropriate control action. This is the basis for operational monitoring and control.
Security Incident Management	To ensure information security events and weaknesses associated with information systems are communicated in a manner allowing timely corrective action to be taken.
Security e-Discovery and Forensics	To collect forensic and e-discovery data and preserve as required in support of forensic investigations.

Backup and Recovery	To maintain the integrity and availability of information and information processing facilities.
InfoSec in Business Continuity Planning	To counteract interruptions to business activities and to protect critical business processes from the effects of major failures of information systems or disasters and to ensure their timely resumption.
Security Metrics	To define metrics to measure the effectiveness of the security program and communicate to relevant stakeholders.
Data Classification	Information assets are classified according to GIP defined classification levels, to ensure that the cost of safeguards and level of protection are proportionate to the value of the asset.

2.6 Compliance and Disciplinary Action

A breach of this policy may lead to discipline, up to and including termination, in accordance with PS 803 Corrective Discipline policy. Similarly, for contracted resources or entities, Government of Saskatchewan will initiate corrective measures up to and including restricting access to services or initiating disciplinary action up to and including termination of a contract or agreement with the contractor, vendor, or agent.

2.7 Exceptions

In certain circumstances, exceptions to this policy may be allowed based a review and acceptance of risk by the Security Governance Committee. Exceptions to this policy must be formally documented and approved by the Chief Information Officer, under the guidance of the Cyber Security and Risk Management Branch. Policy exceptions will be reviewed periodically for appropriateness.

3. GOVERNMENT OF SASKATCHEWAN INFORMATION SECURITY POLICIES

The Information Security Branch, within the Government of Saskatchewan, maintains and provides interpretation and enforcement of information security policies. The Government of Saskatchewan Information Security Policies are based on the ISO/IEC 27001:2013 framework for information security controls and have been reviewed by an independent third-party. This industry-standard framework specifies the requirements for establishing, implementing, maintaining and continually improving an Information Security Management System within the context of the organization. It also includes requirements for the assessment and treatment of information security risks tailored to the needs of the organization.

Each policy document references the corresponding ISO domain to which it aligns. Further, we have referenced the corresponding National Institute of Standards and Technology (NIST) framework as well.

Should you have questions or feedback related to these policy documents, you may engage the Information Security Branch via email at CSITInformationSecurityBranch@gov.sk.ca.

3.1 Information Security Policies

Organization of Information Security

- This policy establishes a framework to initiate and control the implementation and operation of information security within the Government of Saskatchewan.

Asset Management Policy

- This policy is to identify and safeguard government information assets in accordance with their sensitivity and value.

Access Control Policy

- This policy is to ensure proper and effective use of logical and physical access controls to safeguard access to GoS networks, application, and information.

Cryptography Policy

- This policy is to ensure proper and effective use of cryptography to protect the confidentiality and integrity of government information.

Physical and Environmental Security Policy

- This policy is to prevent unauthorized physical access, loss, damage, theft, compromise or interference to the government's information, assets, and operations.

Operations Security Policy

- This policy is to ensure correct and secure operations of information systems.

Communications and Network Security Policy

- This policy is to ensure the protection of information in networks and its supporting information processing facilities, and to maintain the security of information transferred within an organization and with any external entity.

System Acquisition, Development and Maintenance Security Policy

- This policy is to ensure that security is an integral part of information systems across their entire lifecycle.

Security in Supplier Relationships Policy

- This policy is to ensure protection of government information assets that are accessible by suppliers and to maintain an agreed level of information security in line with supplier agreements.

Security Incident Management Policy

- This policy is to ensure a consistent and effective approach to the management of information security incidents, including communication on security events and weaknesses.

Security Aspects of Business Continuity Planning Policy

- This policy is to embed information security continuity in the government's business continuity management systems and to ensure availability of the government's information systems.

Compliance Policy

- This policy is to ensure compliance with all relevant legal, statutory, regulatory, and contractual information security obligations and requirements.